

Business Email Compromise (BEC) response

Email / BEC · **Critical** severity · SOC IR Playbook

Incident type	Social Engineering / Identity Compromise
Severity	Critical
Priority	Critical
Detection sources	Email gateway, SIEM, EDR, user report, cloud email audit logs

Scenario

An attacker gains access to or spoofs a legitimate business email account to deceive internal staff, customers or partners into making unauthorised wire transfers, sharing credentials or altering financial records. This may involve phishing, credential theft or abuse of trusted relationships.

MITRE ATT&CK

T1078, T1114, T1204, T1585.002

Preparation

Enforce multi-factor authentication (MFA) For all business email accounts, especially executives Monitor mailbox activity Enable cloud audit logs for Microsoft 365, Google Workspace Configure email filtering Block spoofed domains, implement SPF, DKIM, DMARC Conduct anti-phishing training Frequent phishing simulations and awareness sessions Define financial control processes Multi-person verification for wire transfers or invoice changes

Detection & Analysis

Identify suspicious activity Unusual login location, new inbox rules, unexpected email content Analyse email headers and metadata Verify sending domain, IP reputation, reply-to address Review mailbox rules and access logs Look for auto-forwarding, deletion filters and unauthorised logins Check for financial or HR engagement Determine if attacker contacted internal or external finance/HR personnel

Containment

Revoke access Reset passwords and invalidate sessions/tokens for affected accounts Disable inbox rules Remove any malicious forwarding or deletion filters Alert potentially impacted users Notify those who received fake requests or were impersonated Block attacker IPs In email platform or at the firewall level if recurring

Eradication

Fully audit affected account Review login history, email sent, calendar changes, contact manipulation Remove malicious artefacts Delete fake emails, remove rogue permissions or shared inbox access Re-secure account Enforce strong password policy and enable conditional access if supported Conduct forensics (if needed) Export logs and preserve evidence for legal or financial investigations

Recovery

Re-enable account access After confirming no ongoing risk Restore legitimate mail flow Clear out auto-forwarding and ensure delivery settings are correct Notify stakeholders Inform internal teams, vendors or clients involved in the incident Monitor for repeat activity Set alerts for high-risk account behaviours for 14-30 days

Lessons Learned & Reporting

Perform root cause analysis Identify how the compromise occurred (phishing, weak password, no MFA) Report financial impact Notify finance, risk and legal teams Engage law enforcement or insurance If fraud occurred or required by policy Update playbook and alerts Enhance detection rules for email forwarding, IP anomalies, login velocity Train employees on social engineering tactics Focus on finance, procurement and executive staff awareness

Tools typically involved

SIEM (e.g., Sentinel, Splunk, QRadar); Email security gateways (e.g., Proofpoint, Mimecast, Microsoft Defender for Office 365); Cloud audit logs (Microsoft 365 Unified Audit Log, Google Workspace Admin Console); Identity platforms (e.g., Okta, Azure AD, Duo); Threat intel feeds for spoofed domain detection and email TTPs

Success metrics (SLA targets)

Detection Time <15 minutes from phishing or suspicious email activity Containment Time <1 hour after confirmation Financial Fraud Prevention Stop wire transfer or mitigate within 24 hours Awareness Campaign Completion 100% of high-risk employees trained post-incident Post-Incident Monitoring Period Minimum of 30 days for affected accounts